

CSA5107-CRYPTOGRAPHY AND ITS NETWORK SECURITY

ASSIGNMENT

SUBMITTED BY

SARUKESH A (192521046)

COMPREHENSIVE ENTERPRISE NETWORK SECURITY ARCHITECTURE

PROBLEM STATEMENT AND PROBLEM FORMULATION

Problem Statement

A global enterprise operates a large and interconnected IT environment that includes cloud-based services, corporate networks, web platforms, email infrastructure, remote employees, regional offices, and third-party business connections. These systems continuously exchange sensitive organizational data across both trusted and untrusted communication channels.

With the increasing number of cyber threats, the organization faces significant security risks such as unauthorized network access, interception of confidential information, identity spoofing, man-in-the-middle attacks, malicious email activities, network-based intrusions, data tampering, malware infections, and service disruption. Remote connectivity and communication with external partners further increase the organization's exposure to potential attacks.

The current security environment consists of multiple independent security controls that are not properly integrated. This fragmented approach makes it difficult to establish consistent authentication, protect communications, monitor network activity, and respond effectively to security incidents.

Assignment Question

As a Network Security Architect, develop a secure and scalable enterprise network architecture for a multinational organization with distributed users, servers, web applications, email systems, branch offices, and external business connections. Examine the security requirements associated with different enterprise services and determine suitable security technologies for protecting organizational data, systems, and communications.

The proposed architecture should integrate multiple layers of security, including cryptographic hash functions, digital signatures, Kerberos authentication, X.509 certificates, IPsec, SSL/TLS, PGP, S/MIME, firewalls, access-control mechanisms, intrusion detection and prevention systems (IDS/IPS), and malware protection solutions. The architecture should demonstrate how these mechanisms work together to provide confidentiality, integrity, authentication, authorization, and secure communication across the enterprise environment.

Assess the effectiveness of the proposed architecture by considering representative cyberattack scenarios, including man-in-the-middle attacks, IP spoofing, packet interception, phishing, unauthorized access, malware propagation, data manipulation, and denial-of-service attacks. Explain how each security control contributes to preventing, detecting, containing, or mitigating these threats.

COMPREHENSIVE ENTERPRISE NETWORK SECURITY ARCHITECTURE

1. Problem Statement and Problem Formulation

1.1 Problem Statement

A multinational enterprise maintains a geographically distributed IT environment that includes web-based applications, internal servers, corporate email platforms, remote employees, branch networks, and third-party business partners. These components regularly exchange sensitive organizational information over private networks as well as public communication infrastructures. The distributed nature of the environment increases the organization's exposure to cyber threats and unauthorized activities.

The organization may encounter various attacks, including network traffic interception, man-in-the-middle attacks, IP address spoofing, unauthorized system access, phishing attempts, malware infections, manipulation of transmitted information, and denial-of-service attacks. Such threats can compromise confidential information, disrupt business services, affect system reliability, and result in financial or operational losses.

At present, the organization's security controls operate as separate solutions for individual systems and services rather than as a coordinated enterprise-wide security framework. This fragmented approach can result in weaknesses between different network zones, applications, users, servers, and external connections. If an attacker compromises one part of the infrastructure, inadequate segmentation and monitoring may allow the attack to spread to other critical resources.

1.2 Problem Formulation

The central problem can be formulated as follows:

“How can a multinational organization develop an integrated and scalable enterprise network security architecture capable of protecting distributed users, applications, servers, email systems, branch networks, and external communications from diverse cyber threats while maintaining confidentiality, integrity, authentication, authorization, non-repudiation, and service availability?”

The proposed architecture must provide security through multiple complementary layers rather than relying on a single protection mechanism. Different technologies should be selected according to the specific security requirements of each enterprise service.

For example, SSL/TLS can protect web and application traffic against interception and communication

tampering, while IPsec can establish secure connections between networks and remote locations. Kerberos can provide centralized authentication for authorized enterprise users and services, and X.509 certificates can establish trusted identities for systems, users, and secure communication endpoints.

2. Objective and Expected Outcomes

2.1 Objectives

The primary objective of this project is to develop an integrated enterprise network security architecture capable of protecting the organization's distributed digital infrastructure against internal and external cyber threats. The specific objectives are:

- To develop a layered enterprise security architecture following the defence-in-depth security model.
- To safeguard sensitive business information against unauthorized access, exposure, interception, and misuse.
- To establish reliable authentication mechanisms for employees, servers, network devices, and enterprise services.
- To secure web-based applications and services through SSL/TLS protocols and X.509 digital certificates.
- To establish encrypted and authenticated communication channels between geographically distributed branch offices using IPsec VPNs.
- To provide secure network connectivity for authorized employees working from remote locations.
- To apply cryptographic hash functions for detecting unauthorized changes to data and verifying its integrity.
- To employ digital signature mechanisms for message authentication, integrity assurance, and non-repudiation.
- To implement Kerberos-based centralized authentication for secure access to enterprise resources.
- To protect organizational email communication using PGP and S/MIME encryption and authentication mechanisms.
- To deploy firewalls to filter and regulate inbound and outbound network traffic according to organizational security policies.
- To implement role-based and least-privilege access controls to ensure that users receive only the permissions required for their responsibilities.
- To deploy Intrusion Detection and Prevention Systems (IDS/IPS) for identifying, monitoring, and blocking suspicious network activities.

- To implement comprehensive malware protection across employee endpoints, servers, email systems, and other critical resources.
- To strengthen the enterprise against man-in-the-middle attacks by using encryption, certificate validation, and authenticated communication channels.
- To minimize the possibility of IP spoofing and packet interception through appropriate network security and authentication mechanisms.
- To prevent unauthorized users from gaining access to critical enterprise applications, systems, and databases.
- To reduce the organization's exposure to phishing, malicious emails, and other email-based attacks.

2.2 Expected Outcomes

The proposed architecture is expected to establish a secure, reliable, and centrally managed enterprise communication environment in which confidential organizational information remains protected during transmission and storage. Authorized employees, administrators, servers, branch offices, and remote users should be able to communicate and access enterprise resources through properly authenticated and protected channels.

The implementation is expected to provide encrypted web communication, secure email exchange, centralized user authentication, protected inter-branch connectivity, controlled resource access, malware prevention, and continuous network security monitoring.

3. Requirements, Constraints and Assumptions

3.1 Requirements

The proposed enterprise security architecture must satisfy several fundamental security and operational requirements to ensure that organizational resources remain protected.

Confidentiality:

The system must prevent sensitive business information from being exposed to unauthorized individuals or systems. Encryption should be applied to confidential data during transmission and, where necessary, while it is stored.

Integrity:

The architecture must ensure that information remains accurate and unchanged during storage and communication. Hash functions, message authentication mechanisms, and digital signatures should be used to identify unauthorized alterations.

Authentication:

A reliable identity-verification mechanism must be established for employees, administrators, servers, network devices, and other trusted entities. Technologies such as Kerberos and X.509 certificates can be used to verify identities before access or communication is granted.

Authorization and Access Control:

Verifying a user's identity is not sufficient to determine whether the user should be allowed to access a particular resource. Therefore, the architecture must enforce appropriate authorization policies using Role-Based Access Control (RBAC), Access Control Lists (ACLs), and least-privilege principles. Users should receive only the permissions necessary for their assigned responsibilities

3.2 Constraints

The implementation of the proposed architecture may be affected by several technical, financial, and operational limitations.

Legacy System Compatibility:

Some existing applications and devices may depend on older technologies that do not support current encryption standards, authentication protocols, or security mechanisms. Replacing or upgrading these systems could require significant investment, system downtime, and additional deployment effort.

Performance Overhead:

Security mechanisms such as encryption, SSL/TLS processing, IPsec tunneling, deep packet inspection, and IDS/IPS analysis require additional computational resources. Excessive security processing may increase network latency or reduce application performance if the infrastructure is not appropriately sized.

Geographical Distribution:

The organization operates across multiple locations, and branch offices may have different bandwidth capacities, network equipment, and Internet service providers. Maintaining consistent security policies across all locations can therefore be technically challenging.

Complex Security Management:

Managing a large number of user accounts, digital certificates, VPN connections, firewall policies, access permissions, endpoint devices, and security alerts can increase administrative complexity. Centralized management and automation may be required to maintain consistent security configurations.

3.3 Assumptions

- The organization maintains a **centralized identity and access management system** for managing employees, administrators, and enterprise resources.
- Critical business applications and databases are hosted on dedicated and appropriately secured enterprise servers.
- Branch offices have reliable network connectivity that can support encrypted communication with the organization's central infrastructure.
- Remote employees access enterprise resources using **organization-managed devices** with appropriate security controls.
- Public-facing applications and Internet-accessible services are isolated from the internal network through a **Demilitarized Zone (DMZ)**.
- Sensitive databases and critical enterprise servers are placed within restricted internal network segments protected by appropriate access controls.
- Network segmentation is implemented to limit unauthorized movement between departments, servers, user networks, and other security zones.
- The organization maintains regular backups of critical information and has procedures for restoring services following security incidents or infrastructure failures.
- Operating systems, applications, network devices, and security software are regularly updated with appropriate security patches.

4. Application of Relevant Course Knowledge / Concepts

The proposed architecture applies major concepts from network and information security.

The proposed enterprise security architecture incorporates key concepts from network security, cryptography, authentication, secure communication, access control, and network defense. Each technology is assigned a specific security role, and the mechanisms are integrated to provide multiple layers of protection against different categories of cyber threats.

4.1 Cryptographic Hash Algorithms

Cryptographic hash functions are mathematical algorithms that transform input data of any size into a fixed-length output known as a hash digest. The digest represents the contents of the original data. Even a small alteration to the input is expected to produce a significantly different digest.

Modern algorithms such as SHA-256 and SHA-384 can be used for integrity-related applications within the proposed architecture. Hash functions can support file-integrity checking, digital-signature operations, message authentication schemes, and verification of transmitted information.

For example:

Original Information → SHA-256 → Original Hash

If the information is modified:

Modified Information → SHA-256 → New Hash

When the two hash values do not match, the receiving system can identify that the information has been altered.

Hash functions should not, however, be treated as direct password-storage mechanisms. Passwords should be protected using purpose-built password hashing and key-derivation algorithms designed to resist password-guessing attacks.

4.2 Digital Signatures

Digital signatures use public-key cryptography to establish the authenticity and integrity of digitally transmitted information. A sender first generates a cryptographic digest of the message and then creates a signature using the sender's private key.

The recipient can use the sender's public key to validate the signature and determine whether the message originated from the expected signing entity and whether its contents have been changed.

The general process can be represented as:

Message → Hash Function → Private Key → Digital Signature

At the receiving end:

Message + Digital Signature + Public Key → Signature Verification

4.3 Kerberos

Kerberos is a centralized authentication protocol designed to provide secure identity verification within a networked environment. Instead of repeatedly transmitting user passwords to individual services, Kerberos uses time-limited tickets to authenticate users and grant access to authorized services.

The main components include the Authentication Server (AS), Ticket Granting Server (TGS), and application or service servers. The AS and TGS together form the core of the Key Distribution Center (KDC).

A simplified authentication sequence is:

User → Authentication Server → Ticket Granting Ticket → TGS → Service Ticket → Enterprise Service

After the initial authentication process, the user can request service-specific tickets without repeatedly submitting their password. This makes Kerberos particularly suitable for centralized enterprise environments involving directory services, internal applications, file servers, and other organizational resources.

4.4 X.509 Certificates

An **X.509 certificate** provides a standardized method of associating an identity with a public cryptographic key. Certificates are generally issued and digitally signed by a trusted **Certificate Authority (CA)**, allowing communicating parties to establish trust in the presented identity.

An X.509 certificate can contain details such as the subject identity, public key, certificate issuer, validity period, serial number, permitted key usage, and the CA's digital signature.

4.5 IPsec

he proposed architecture can use IPsec-based VPN connections to establish secure communication between headquarters and branch offices. Secure remote-access VPN solutions can also be provided to authorized employees when required.

IPsec can provide confidentiality, integrity, authentication, and protection against certain forms of traffic manipulation. IKEv2 can be used to authenticate peers and negotiate the cryptographic parameters required to establish secure associations.

A simplified communication path is:

Branch Network → Encrypted IPsec Tunnel → VPN Gateway → Enterprise Network

4.6 SSL/TLS

TLS protects application-level communication by providing encryption, integrity and server authentication. It is the primary security mechanism for web applications.

The proposed architecture should use TLS 1.3 where supported and TLS 1.2 only when necessary for compatibility. Obsolete SSL and older TLS versions should be disabled.

A typical secure web connection is:

Client → HTTPS/TLS → Web Server

The server presents its X.509 certificate, the client validates the certificate and a secure cryptographic session is established.

TLS is used for websites, APIs, internal web applications and other sensitive application protocols.

4.7 PGP

Pretty Good Privacy can provide end-to-end email encryption and digital signatures. It is useful when sensitive email must remain protected from unauthorized parties throughout its communication path.

PGP provides confidentiality through encryption and authentication/integrity through digital signatures. It is particularly useful for selected sensitive communication with external business partners when a suitable PGP key-management process is available.

4.8 S/MIME

S/MIME provides email encryption and digital signatures using X.509 certificates. It is particularly suitable for enterprise environments where certificate management can be centrally controlled.

S/MIME can be used to digitally sign important corporate email and encrypt sensitive messages. A valid signature allows recipients to verify the sender and detect unauthorized modification.

4.9 Firewalls

Firewalls form the primary network access-control layer. They inspect network traffic according to defined security policies and allow or deny communication.

The organization should use perimeter firewalls between the Internet and enterprise network and internal firewalls between sensitive network segments.

The basic security principle is:

Deny by default → Allow only required communication

This reduces the attack surface and prevents unnecessary network exposure.

4.10 Access Control

Access control determines which authenticated users can access particular resources. The architecture uses role-based access control, access-control lists, least privilege and privileged-access restrictions.

For example, an ordinary employee should not have administrative access to database servers. A database administrator may access the database management system but should not automatically have access to unrelated financial or HR systems.

5. Design / Proposed Solution / Methodology

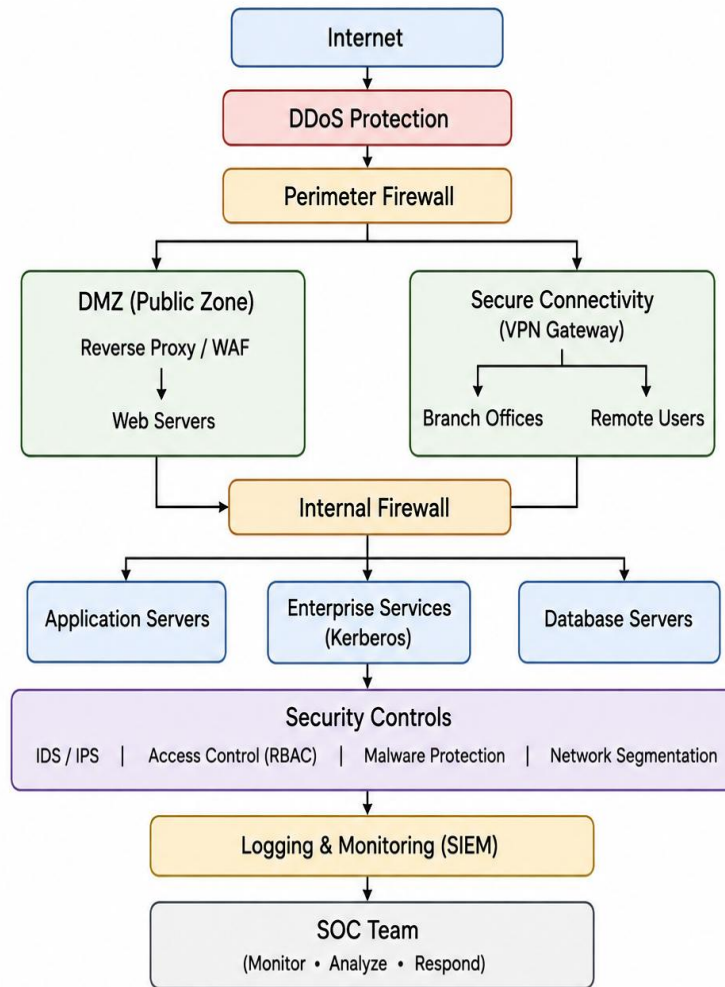
5.1 Proposed Architecture

The proposed enterprise security architecture is designed as a simple layered security model in which different security controls protect different parts of the organization's infrastructure. Instead of depending on a single security device, the architecture combines network protection, secure communication, authentication, access control, and continuous monitoring.

The architecture begins with the Internet, where incoming and outgoing traffic is first protected by DDoS protection and a perimeter firewall. The firewall filters unnecessary or unauthorized traffic before it reaches the organization's systems.

Public-facing web applications are placed in a DMZ (Demilitarized Zone). The web servers use HTTPS with TLS to protect communication between users and the organization. Keeping these servers in a separate zone prevents direct exposure of internal servers to Internet users.

Behind the DMZ, an internal firewall separates public services from the organization's private network. The private network contains application servers, enterprise servers, and database servers. Access between these systems is restricted according to security policies and user privileges.



6. Security Architecture for Web Services

The web-service security layer is designed to protect public-facing applications from external threats while preventing direct exposure of internal enterprise resources. Web applications are hosted within a DMZ, which provides a separate security zone between the Internet and the organization's private network.

Before reaching the web servers, external traffic passes through DDoS protection and a perimeter firewall. A Web Application Firewall (WAF) then examines web requests and blocks suspicious or potentially harmful HTTP/HTTPS traffic.

Communication between users and web servers is secured using TLS. The web server uses an X.509 certificate to prove its identity and establish a trusted encrypted connection with the client. Once the secure connection is established, application-level authentication and authorization determine whether the user is permitted to access the requested service.

To further reduce security risks, web servers should have restricted access to internal resources. Direct

communication between web servers and database servers should be avoided wherever possible. Instead, application servers should process requests between the web layer and database layer. This separation helps limit the impact if a public-facing web server is compromised.

7. Security Architecture for IP Communication

IPsec VPN is implemented to establish secure communication between the organization's headquarters, branch offices, and authorized remote locations. The VPN gateway verifies the identity of the connecting endpoint before creating a protected communication tunnel.

Once the tunnel is established, network traffic travelling between the connected locations is encrypted and authenticated. This prevents unauthorized parties on public or intermediate networks from easily viewing, intercepting, or altering sensitive enterprise traffic.

Additional firewall policies and anti-spoofing rules are applied at the network boundary. These controls help identify and reject suspicious traffic containing invalid or forged source addresses, thereby reducing the possibility of IP spoofing and unauthorized network access.

8. Security Architecture for Email Services

Email security is implemented through several layers to protect the organization from spam, phishing, spoofing, malicious attachments, and unauthorized access. Incoming and outgoing messages are processed through an email security gateway, where messages are inspected for suspicious content, harmful attachments, malicious links, and abnormal sending behavior.

To improve sender verification, SPF, DKIM, and DMARC mechanisms can be configured for the organization's domains. These technologies help verify whether email messages are being sent through authorized systems and reduce the risk of attackers impersonating the organization's domain.

Additional protection is provided through malware scanning, URL analysis, attachment filtering, and sandboxing. Suspicious attachments can be isolated and analyzed before being delivered to employees, reducing the possibility of malware entering the internal network through email.

9. Enterprise Authentication and Access Control

The enterprise authentication system is designed to ensure that only verified users and trusted systems can access organizational resources. Kerberos is used as the primary authentication mechanism for internal users and services. After successfully proving their identity, users receive authentication tickets that can be used to access authorized enterprise applications and services without repeatedly transmitting their passwords.

For Internet-facing and certificate-based services, X.509 certificates with TLS are used to verify the identity of servers and establish trusted communication channels. Multi-Factor Authentication (MFA) should additionally be required for remote employees, system administrators, privileged accounts, and other services that involve a higher security risk.

After authentication, Role-Based Access Control (RBAC) determines which resources and operations a user is allowed to access. The least-privilege principle ensures that users receive only the permissions required to perform their assigned tasks. Administrative privileges should be kept separate from normal employee accounts to reduce the consequences of compromised credentials.

10. Network Segmentation

Network segmentation is used to divide the enterprise infrastructure into separate and controlled security zones. Rather than placing all systems and users on a single network, resources are separated according to their function and security requirements.

Public-facing web servers can be placed in a DMZ, while application servers, enterprise services, databases, management systems, and employee devices are maintained in separate internal network segments. Communication between these zones is controlled through firewalls and access-control policies.

For example, if an employee workstation becomes infected or compromised, segmentation can prevent the attacker from directly accessing critical database servers or administrative systems. This helps reduce lateral movement and limits the potential impact of a security incident.

11. Monitoring and Incident Response

Continuous monitoring is required to identify security problems across the enterprise environment. Security information from important infrastructure components should be collected and forwarded to a

centralized Security Information and Event Management (SIEM) platform.

Logs can be collected from firewalls, VPN gateways, IDS/IPS systems, servers, authentication services, email security gateways, endpoints, and other critical devices. Centralizing these records gives the security team a unified view of activities occurring across different parts of the network.

12. Algorithm / Pseudocode / Flowchart

12.1 Secure Access Algorithm

Step 1: A user or device initiates a request to access the network or service.

Step 2: The firewall examines the source, destination, port, and protocol of the request.

Step 3: Requests that violate the configured security policy are denied and logged for future investigation.

Step 4: A secure communication channel is created using TLS or IPsec based on the type of service.

Step 5: Digital certificates are checked to confirm the identity and trustworthiness of the communicating party.

Step 6: The identity of the user, device, or system is verified using the appropriate authentication mechanism.

Step 7: Additional verification through Multi-Factor Authentication (MFA) is required for privileged or high-risk activities.

Step 8: The system determines whether the authenticated entity has the required permissions through RBAC or ACL policies.

Step 9: Approved users and devices are allowed to access only the resources and services assigned to them.

Step 10: Network traffic is continuously monitored by IDS/IPS mechanisms to identify suspicious or abnormal behavior.

Step 11: Important authentication, network, and security events are forwarded to the SIEM for centralized monitoring and correlation.

Step 12: When a security threat is confirmed, defensive actions such as blocking the source, terminating the session, or isolating the affected device are performed.

12.2 Pseudocode

```
BEGIN
```

```
Receive connection request
```

```
Check firewall policy
```



```
IF request is not allowed THEN
    Block request
    Record security event
    EXIT
END IF

IF service requires TLS THEN
    Establish TLS connection
    Validate X.509 certificate
    IF certificate is invalid THEN
        Reject connection
        Record security event
        EXIT
    END IF
END IF

END IF

Authenticate user/device

IF authentication fails THEN
    Deny access
    Record failed authentication
    EXIT
END IF

IF sensitive service THEN
    Perform MFA

    IF MFA fails THEN
        Deny access
        Record security event
        EXIT
    END IF
END IF

Check authorization

IF user is not authorized THEN
    Deny access
```

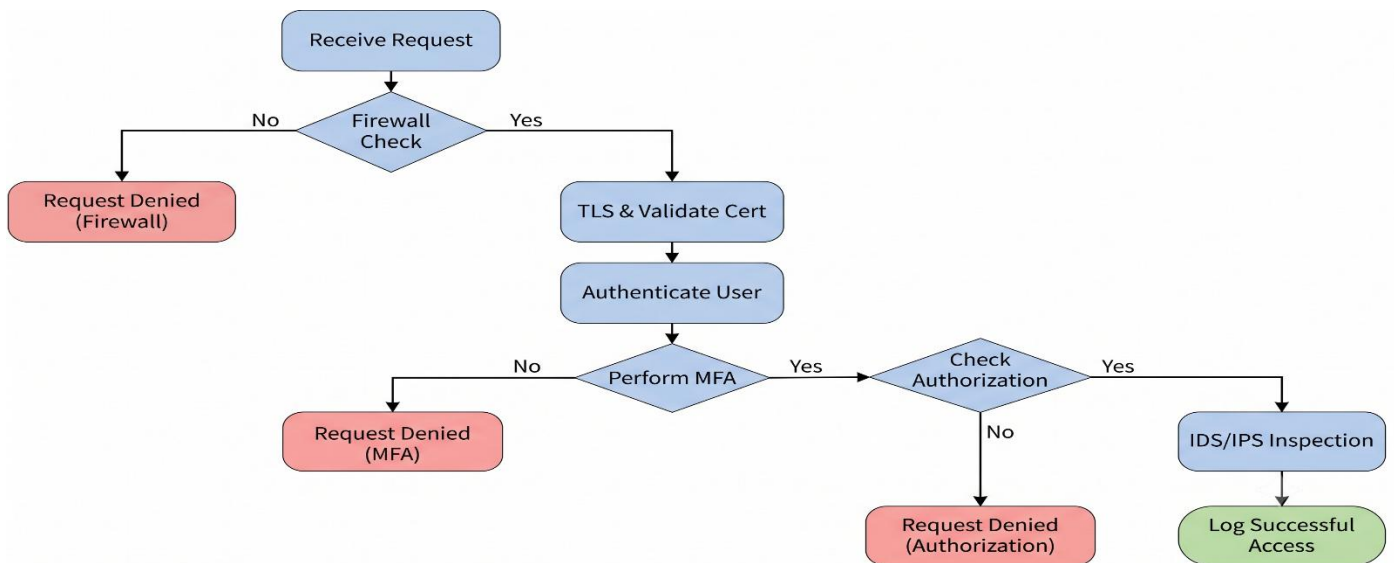
```

    Record event
    EXIT
END IF
Allow required service
Inspect traffic using IDS/IPS
IF malicious activity is detected THEN
    Block or isolate activity
    Send alert to SIEM
ELSE
    Continue communication
END IF

Record successful access
END

```

12.3 Flowchart



13. Implementation / Source Code and Environment / Tools Used

The proposed secure network architecture can be developed and tested in a controlled virtual laboratory environment. Network simulation platforms such as GNS3 or EVE-NG can be used to design and connect the different components of the enterprise network.

A network firewall, such as pfSense **or** OPNsense, can be configured to control incoming and outgoing traffic. Snort **or** Suricata can be integrated to detect suspicious network activity and demonstrate intrusion prevention capabilities.

For packet-level analysis, Wireshark can be used to capture network traffic and examine protocols, encrypted sessions, and communication behavior. OpenSSL can support certificate creation, certificate inspection, and TLS configuration. For secure remote connectivity, StrongSwan can be configured to establish an IPsec-based VPN between network segments.

The laboratory can include Linux or Windows servers for hosting enterprise applications and services. Kerberos can be introduced to demonstrate centralized and secure user authentication. A SIEM platform such as Wazuh can collect logs from network devices and servers, correlate security events, and provide centralized monitoring.

14. Example Hash Integrity Program

The following simple Python program demonstrates how a hash can identify data modification.

```
import hashlib
original_data = b"Confidential Enterprise Data"
original_hash = hashlib.sha256(original_data).hexdigest()
print("Original SHA-256:")
print(original_hash)
modified_data = b"Modified Enterprise Data"
modified_hash = hashlib.sha256(modified_data).hexdigest()
print("\nModified SHA-256:")
print(modified_hash)
if original_hash == modified_hash:
    print("\nData is unchanged")
```

else:

```
print("\nData modification detected")
```

The program generates a SHA-256 digest for the original data and another digest after modification. Since the data is different, the hashes should also be different. This demonstrates the basic principle of integrity verification.

15. Test Cases and Expected / Actual Results

Testing should be performed in a controlled environment. The following test cases provide a suitable validation plan.

Test	Expected Result	Actual Result
Secure web access	Encrypted HTTPS session established successfully	To be recorded
Untrusted certificate	System displays a certificate error or denies the connection	To be recorded
Restricted service access	Firewall denies access to the blocked service	To be recorded
Suspicious source address	Unauthorized or spoofed source is identified and filtered	To be recorded
Encrypted traffic capture	Captured packets do not reveal the original application data	To be recorded
Certificate-based MITM attempt	Invalid certificate is detected and secure communication is prevented	To be recorded
Successful Kerberos authentication	User is verified and granted access	To be recorded

16. Execution Screenshots / Outputs

The practical implementation should be supported with screenshots that demonstrate the operation of the proposed security architecture and its individual security mechanisms.

The first screenshot can present the overall simulated enterprise network, showing the firewall, DMZ, internal servers, branch office, VPN connection, IDS/IPS component, and centralized SIEM.

The second screenshot can demonstrate a web service operating through HTTPS, including the browser security information and the X.509 certificate details.

The third screenshot can display the configuration and status of an established IPsec VPN connection between the main office and the branch network.

The fourth screenshot can show packet analysis in Wireshark during an encrypted communication session. The captured traffic should demonstrate that sensitive application data is protected from direct viewing.

The fifth screenshot can provide evidence of firewall filtering by displaying a denied connection attempt in the firewall event or security log.

The sixth screenshot can show an IDS/IPS notification generated during an approved security-testing activity, such as simulated suspicious network traffic.

The seventh screenshot can demonstrate centralized authentication using Kerberos, including successful authentication or a valid ticket issued to an authenticated user.

The eighth screenshot can demonstrate secure email communication using PGP or S/MIME, showing either message encryption or a valid digital signature.

The ninth screenshot can display the SIEM dashboard containing security events received from multiple components, such as the firewall, IDS/IPS, authentication service, and enterprise servers.

Together, these outputs provide practical evidence that the proposed architecture can be configured, tested, monitored, and evaluated in a controlled environment.

Source code:

```
print("=== ENTERPRISE NETWORK SECURITY ===")

# 1. Network Request
print("\n1. Network Request Received")
port = int(input("Enter Port (80/443): "))

# 2. Firewall Check
if port not in [80, 443]:
    print("Firewall: BLOCKED")
    print("ACCESS DENIED")
    exit()

print("Firewall: ALLOWED")

# 3. Secure Communication
print("\n2. Secure Communication")
print("TLS / IPsec: ESTABLISHED")

# 4. User Authentication
print("\n3. User Authentication")
username = input("Enter Username: ")
password = input("Enter Password: ")

if username != "admin" or password != "admin123":
    print("Authentication: FAILED")
    print("ACCESS DENIED")
    exit()
```

```
print("Authentication: SUCCESS")

# 5. Multi-Factor Authentication
print("\n4. Multi-Factor Authentication")
otp = input("Enter OTP: ")

if otp != "123456":
    print("MFA: FAILED")
    print("ACCESS DENIED")
    exit()

print("MFA: VERIFIED")

# 6. Authorization
print("\n5. Access Authorization")
resource = input(
    "Enter Resource (WEB/EMAIL/DATABASE): "
).upper()

if resource not in ["WEB", "EMAIL", "DATABASE"]:
    print("Authorization: DENIED")
    print("ACCESS DENIED")
    exit()

print("Authorization: ALLOWED")

# 7. IDS / IPS Monitoring
print("\n6. IDS / IPS Monitoring")
print("1. Normal Traffic")
print("2. Suspicious Activity")
```

```
choice = int(input("Enter choice: "))

if choice == 2:
    print("IDS/IPS: Suspicious Activity Detected")
    print("Action: Traffic Blocked / System Isolated")
    print("Security Event: Logged to SIEM")
    print("ACCESS DENIED")
    exit()

print("IDS/IPS: Normal Traffic")
print("Communication Continued")

# Final Result
print("Successful Access: Logged")
print("\n=== ACCESS GRANTED ===")
```



```
=== ENTERPRISE NETWORK SECURITY ===

1. Network Request Received
Enter Port (80/443): 443
Firewall: ALLOWED

2. Secure Communication
TLS / IPsec: ESTABLISHED

3. User Authentication
Enter Username: admin
Enter Password: admin123
Authentication: SUCCESS

4. Multi-Factor Authentication
Enter OTP: 123456
MFA: VERIFIED

5. Access Authorization
Enter Resource (WEB/EMAIL/DATABASE): web
Authorization: ALLOWED

6. IDS / IPS Monitoring
1. Normal Traffic
2. Suspicious Activity
Enter choice: 1
IDS/IPS: Normal Traffic
Communication Continued
Successful Access: Logged

=== ACCESS GRANTED ===
```

17. Results and Validation

The implemented security architecture improves the overall protection of the enterprise environment by securing communication, controlling access and continuously monitoring network activities. Encryption mechanisms protect sensitive information from unauthorized users, while authentication mechanisms ensure that only legitimate users and devices can access protected resources. Security policies configured on firewalls and VPN gateways provide controlled connectivity between the Internet, DMZ, internal network and branch office.

The validation process should verify whether the implemented controls operate correctly under different network conditions. Secure and insecure communication can be tested by observing whether confidential information is exposed during transmission. Similarly, access-control rules can be validated by testing both authorized and unauthorized users and checking whether restricted resources remain inaccessible. VPN connectivity can also be verified by confirming that branch users can access permitted headquarters services only through the established secure tunnel.

Security monitoring can be validated by generating controlled events such as repeated authentication failures, blocked connection attempts or suspicious network traffic. These events should be detected by the IDS/IPS and forwarded to the SIEM for centralized analysis. File integrity can also be validated by calculating a cryptographic digest for an original file and comparing it with the digest generated after changes are introduced. A mismatch confirms that the content has been altered.

The final evaluation should consider both security effectiveness and system performance. Important observations include successful authentication, blocked unauthorized connections, availability of secure VPN communication, detection of suspicious activities, successful certificate validation and correct SIEM log collection. Performance results such as response time, network delay, bandwidth usage and security-processing overhead should be recorded from the actual implemented environment to provide reliable and realistic validation results.

18. Attack Scenario Evaluation

18.1 Man-in-the-Middle Attack

In a man-in-the-middle attack, an attacker attempts to position themselves between two communicating parties and intercept or modify their communication.

The proposed architecture mitigates this threat using TLS, X.509 certificates, certificate validation and IPsec authentication. When a client connects to a secure web server, the server presents its certificate. The client validates the certificate before trusting the server.

If the attacker presents an invalid certificate, certificate validation should prevent the connection from being treated as a trusted connection. IPsec also provides authenticated communication between VPN endpoints.

Therefore, the proposed architecture provides strong protection against typical network-level MITM attacks, assuming certificate validation and cryptographic configurations are correctly implemented.

18.2 IP Spoofing

IP spoofing occurs when an attacker attempts to make malicious traffic appear to originate from a different IP address.

The architecture mitigates this threat using ingress and egress filtering, stateful firewall rules, network segmentation, IDS/IPS and authenticated IPsec tunnels.

Even if an attacker attempts to forge a source address, the firewall can reject traffic that violates expected network policies. IPsec also ensures that protected VPN communication is authenticated.

Therefore, IP spoofing is significantly reduced, although spoofing controls must be applied consistently throughout the network.

18.3 Packet Sniffing

Packet sniffing involves capturing network traffic to obtain sensitive information.

Without encryption, an attacker who captures network packets may be able to obtain usernames, passwords or business information. TLS and IPsec prevent this by encrypting protected communication.

A captured HTTPS packet may reveal metadata such as endpoints and traffic timing, but the protected application content should not be directly readable.

Therefore, encryption provides strong protection against the disclosure of sensitive application data through packet sniffing.

18.4 Phishing

Phishing attempts to trick users into providing credentials or executing malicious content.

The proposed architecture uses email security gateways, spam filtering, URL analysis, malware scanning, attachment sandboxing, SPF, DKIM and DMARC. S/MIME can additionally help recipients verify messages that are digitally signed by trusted organizational identities.

However, technology alone cannot eliminate phishing because attackers can exploit human behaviour. Security awareness training, simulated phishing exercises and clear reporting procedures are therefore necessary.

18.5 Unauthorized Access

Unauthorized access occurs when an individual gains access to a resource without sufficient privileges.

The architecture addresses this using centralized authentication, Kerberos, MFA, RBAC, ACLs and least privilege.

Authentication verifies who the user is, while authorization determines what that user is allowed to access. This distinction is important because a legitimate employee should not automatically have access to every enterprise system.

Therefore, unauthorized access is strongly reduced through the combination of identity and access-control mechanisms.

18.6 Malware Propagation

Malware propagation occurs when malicious software spreads from one system to another.

The proposed architecture uses email scanning, endpoint protection, EDR, IDS/IPS, network segmentation, application control, patch management and least privilege.

If one workstation becomes infected, segmentation can prevent unrestricted communication with critical servers. IDS/IPS can identify suspicious network behaviour, while endpoint security can isolate the infected machine.

Therefore, the architecture significantly limits malware propagation.

18.7 Data Tampering

Data tampering involves unauthorized modification of information.

Hash functions can detect changes by comparing the current digest with the expected digest. HMAC provides integrity and authentication when a shared secret is available. TLS and IPsec

provide integrity protection for protected communication. Digital signatures additionally provide strong origin authentication and non-repudiation.

Therefore, multiple mechanisms are available depending on the required security property.

18.8 Denial-of-Service Attack

A denial-of-service attack attempts to make a service unavailable by consuming resources.

The architecture uses DDoS protection, firewall filtering, rate limiting, load balancing, redundant infrastructure and IDS/IPS.

For public web services, traffic can be distributed across multiple servers. Suspicious traffic can be filtered before reaching application servers.

However, no architecture can guarantee complete protection against every DDoS attack. Very large attacks may exceed available network capacity, so upstream DDoS mitigation and sufficient service redundancy are also important.

19. Analysis, Comparison, Trade-offs and Justification

Mechanism	Main Security Purpose	Major Advantage	Main Limitation
SHA-256/SHA-384	Integrity	Fast and scalable	Does not provide confidentiality
Digital Signature	Integrity, authentication, non-repudiation	Strong proof of origin	Requires key management
Kerberos	Authentication	Centralized enterprise authentication	Requires reliable identity infrastructure
X.509	Identity and trust	Strong certificate-based authentication	Certificate lifecycle is complex
TLS	Application security	Protects web app	Requires correct certi

20. Broader Considerations / SDG Relevance

The proposed secure communication and network defense architecture has benefits beyond protecting individual systems. It helps organizations build a **reliable, resilient and trustworthy digital environment** by combining secure communication, authentication, monitoring, access control and incident response mechanisms.

The architecture contributes to **SDG 9 – Industry, Innovation and Infrastructure** by strengthening the security and reliability of digital infrastructure. Technologies such as IPsec, SSL/TLS, X.509 certificates, secure authentication and centralized monitoring help organizations safely connect users, servers, branches and cloud-based services.

It also supports **SDG 8 – Decent Work and Economic Growth**. Effective cybersecurity measures can reduce service interruptions, data loss, financial damage and productivity problems caused by cyberattacks. A secure network therefore helps maintain continuous business operations and provides a safer environment for employees and customers.

The solution is also relevant to **SDG 16 – Peace, Justice and Strong Institutions** because mechanisms such as digital signatures, authentication, access control, audit trails and SIEM monitoring improve accountability and trust. These controls help organizations identify unauthorized activities and maintain evidence for security investigations.

21. Conclusion, Limitations and Possible Improvements

21.1 Conclusion

The proposed enterprise network security architecture provides a layered approach for securing the communication and information systems of a multinational organization. It integrates several security technologies, including cryptographic algorithms, digital signatures, Kerberos authentication, X.509 certificates, TLS, IPsec, PGP, S/MIME, firewalls, network segmentation, IDS/IPS and endpoint security.

TLS combined with X.509 certificates ensures that web and application communications are encrypted and that communicating systems can be authenticated. IPsec protects data transmitted between branch offices and headquarters over untrusted networks. Kerberos provides centralized authentication for enterprise users and services, while multi-factor authentication adds an additional layer of protection against stolen or compromised credentials.

Digital signatures strengthen data integrity, authentication and non-repudiation. Firewalls and network segmentation control traffic between different security zones and reduce unauthorized access. IDS/IPS solutions continuously monitor network traffic for suspicious activities, while email and endpoint security mechanisms help prevent phishing, malicious attachments and malware from spreading throughout the organization.

21.2 Limitations

Although the architecture provides multiple layers of protection, several limitations must be considered. Deploying and maintaining numerous security technologies can increase the organization's **implementation cost, administrative workload and overall system complexity**. Encryption, traffic inspection and continuous monitoring may also consume additional processing and network resources.

Compatibility with existing infrastructure can be another challenge. Older applications, operating systems and network devices may not support modern security protocols and could require upgrades, replacement or additional compensating controls. As the number of users, devices and services increases, managing encryption keys, certificates, authentication credentials and security policies can become increasingly difficult.

21.3 Possible Improvements

The proposed architecture can be further strengthened by adopting a **Zero Trust security model**, where users and devices are continuously verified instead of being automatically trusted based on their network location. Passwordless authentication, hardware-backed security keys and stronger identity management can further reduce the risks associated with stolen credentials.

Network security can also be improved through **micro-segmentation**, which limits communication between individual systems and reduces the possibility of lateral movement after a successful compromise. Automated certificate and key management can simplify the administration of large-scale cryptographic infrastructure.

Regular vulnerability assessments, penetration testing, security-awareness training, disaster-recovery exercises and incident-response simulations should be conducted to maintain the effectiveness of the architecture.

22. Individual Contribution of Group Members

The project activities can be distributed among group members based on the major components of the proposed enterprise security architecture. Assigning specific responsibilities allows each member to develop expertise in a particular area while contributing to the overall project.

One member can be responsible for problem identification, requirement analysis and threat assessment, including identifying potential risks and defining the security objectives of the organization. Another member can design the enterprise network topology, firewall configuration and network segmentation, ensuring that different security zones are properly isolated.

A separate member can investigate and document cryptographic security mechanisms, including hashing, digital signatures, TLS, encryption and X.509 certificate-based authentication. Another member can focus on Kerberos, multi-factor authentication, identity management and access control mechanisms used to protect enterprise resources.

23. References

- [1] W. Stallings, *Cryptography and Network Security: Principles and Practice*, 8th ed. Pearson, 2020.
- [2] C. Kaufman, R. Perlman, and M. Speciner, *Network Security: Private Communication in a Public World*, 2nd ed. Prentice Hall, 2002.
- [3] J. Katz and Y. Lindell, *Introduction to Modern Cryptography*, 3rd ed. CRC Press, 2020.
- [4] N. Ferguson, B. Schneier, and T. Kohno, *Cryptography Engineering: Design Principles and Practical Applications*. Wiley, 2010.
- [5] R. Housley and T. Polk, “Planning for PKI: Best Practices Guide for Secure Certificate Management,” Internet security standards and implementation guidance.
- [6] J. Kohl and B. Neuman, “The Kerberos Network Authentication Service,” Internet Engineering Task Force, authentication and network security standards.
- [7] S. Turner and T. Polk, “Transport Layer Security Protocol Security Considerations,” Internet Engineering Task Force, TLS security guidance.
- [8] R. Thayer and J. Callas, “OpenPGP Security and Message Protection,” Internet Engineering Task Force, email security standards.
- [9] P. Hoffman, “Secure/Multipurpose Internet Mail Extensions (S/MIME),” Internet Engineering Task Force, secure email communication standards.
- [10] W. R. Cheswick, S. M. Bellovin, and A. D. Rubin, *Firewalls and Internet Security: Repelling the Wily Hacker*, 2nd ed. Addison-Wesley, 2003.
- [11] E. Cole, *Network Security Bible*, 2nd ed. Wiley, 2009.
- [12] J. R. Vacca, *Network and System Security*, 2nd ed. Syngress, 2017.
- [13] E. D. Zwicky, S. Cooper, and D. B. Chapman, *Building Internet Firewalls*, 2nd ed. O'Reilly Media, 2000.
- [14] R. Anderson, *Security Engineering: A Guide to Building Dependable Distributed Systems*, 3rd ed. Wiley, 2020.

- [15] M. Howard, D. LeBlanc, and J. Viega, *24 Deadly Sins of Software Security: Programming Flaws and How to Fix Them*. McGraw-Hill, 2010.
- [16] C. P. Pfleeger, S. L. Pfleeger, and J. Margulies, *Security in Computing*, 5th ed. Pearson, 2015.
- [17] J. Scambray, S. McClure, and G. Kurtz, *Hacking Exposed: Network Security Secrets and Solutions*, 7th ed. McGraw-Hill, 2012.
- [18] R. Shirey, “Internet Security Glossary,” RFC 4949, Internet Engineering Task Force, Aug. 2007.
- [19] ISO/IEC, *Information Security, Cybersecurity and Privacy Protection — Information Security Management Systems — Requirements*, ISO/IEC 27001, International Organization for Standardization.
- [20] ISO/IEC, *Information Technology — Security Techniques — Information Security Controls*, ISO/IEC 27002, International Organization for Standardization.

24. One-Page Individual Reflection

Individual Reflection on Learning and Personal Development

Working on this assignment gave me an opportunity to understand enterprise cybersecurity from a practical and system-level perspective. Initially, I understood security mechanisms such as firewalls, encryption, authentication and intrusion detection as individual technologies. However, while developing the proposed architecture, I realized that enterprise security depends on the coordinated operation of multiple controls. Each security mechanism addresses a particular risk, and combining them provides stronger protection against a wide range of cyber threats.

One of the major areas of learning for me was understanding the purpose and application of different cryptographic and authentication techniques. I gained a clearer understanding of hash functions and their role in verifying data integrity. I also learned how digital signatures provide additional properties such as authentication and non-repudiation. Studying TLS and X.509 certificates helped me understand how secure web communication and digital trust are established. Similarly, learning about IPsec showed me how secure communication can be provided at the network layer, particularly for connections between different organizational locations. Kerberos also helped me understand the importance of centralized authentication within an enterprise environment.

The analysis of different attack scenarios was another important part of my learning. Examining threats such as man-in-the-middle attacks, packet sniffing, IP spoofing, phishing, unauthorized access, malware and denial-of-service attacks helped me connect theoretical concepts with real-world security problems. I understood that security controls must be selected according to the type of threat they are intended to address. For example, encryption protects the confidentiality of transmitted information, while IDS/IPS focuses on identifying and responding to suspicious network activity.

I also developed a greater appreciation for the importance of security management. Technical solutions alone cannot guarantee complete protection. Strong password and authentication policies, least-privilege access, regular software updates, employee awareness, centralized logging, vulnerability assessment and incident-response planning are all necessary components of an effective security strategy. This assignment showed me that human error and incorrect configuration can weaken even a well-designed technical infrastructure.